SENTINEL APPSEC | APPLICATION SECURITY VERIFICATION

https://tmvoid.github.io/lakshit-site/

Report ID: sentinel-audit-1794152659457 | Duration: 1319 ms

Date: Sun, 08 Nov 2026 15:44:19 GMT | URL: https://tmvoid.github.io/lakshit-site/

CRITICAL	HIGH	MEDIUM	LOW	PASSED
0	0	1	2	12

1. Executive Verification Summary

The Sentinel AppSec engine verified 3 security finding(s) backed by empirical HTTP header responses, SPA-filtered sensitive route probes, live OSV.dev CVE advisories, or exact source code line matches, alongside 12 passed security control(s).

2. Empirical Vulnerability Ledger (3)

01. [MEDIUM] Missing Clickjacking Protection (X-Frame-Options / frame-ancestors)

CWE-1021 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/

Summary: Neither X-Frame-Options nor CSP frame-ancestors is present on the HTTP response.

Impact: Malicious external sites can embed this application inside an invisible <iframe> and trick students into clicking authenticated buttons (UI Redressing / Clickjacking).

```
x-frame-options: <ABSENT>
content-security-policy frame-ancestors: <ABSENT>

Actual Response Headers:
accept-ranges: bytes
access-control-allow-origin: *
age: 0
cache-control: max-age=600
```

Remediation: Set X-Frame-Options to DENY or SAMEORIGIN and add frame-ancestors 'none' to your Content-Security-Policy.

02. [LOW] Missing X-Content-Type-Options: nosniff Header

CWE-16 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/

Summary: The server does not send X-Content-Type-Options: nosniff, allowing browsers to MIME-sniff response bodies.

Impact: Browsers may interpret user-uploaded text or image files as executable HTML or JavaScript.

```
x-content-type-options: <ABSENT>

Actual Response Headers:
accept-ranges: bytes
access-control-allow-origin: *
age: 0
cache-control: max-age=600
connection: keep-alive
```

Remediation: Send X-Content-Type-Options: nosniff on all HTTP responses.

03. [LOW] Permissive Wildcard CORS Policy (Access-Control-Allow-Origin: *)

`CWE-942 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/`

Summary: The endpoint returns Access-Control-Allow-Origin: *, permitting any external origin to read public response data via fetch/XHR.

Impact: If applied globally to authenticated or internal API routes, untrusted origins may read sensitive application responses.

```
Access-Control-Allow-Origin: *
```

Remediation: Restrict Access-Control-Allow-Origin to explicit trusted origins unless the endpoint is intentionally a public read-only API.

3. Verified Passed Security Controls (12)

[PASS] **Encrypted Transport / HTTPS Context Verified (https://tmvoid.github.io/lakshit-site/)**
`Transport verified on https://tmvoid.github.io/lakshit-site/ (HTTP 200)`

[PASS] **Content-Security-Policy (CSP) Enforced (https://tmvoid.github.io/lakshit-site/)**
`content-security-policy: default-src`

[PASS] **HTTP Strict-Transport-Security (HSTS) Active (https://tmvoid.github.io/lakshit-site/)**
`strict-transport-security: max-age=31556952`

[PASS] **Framework Fingerprinting Headers (X-Powered-By) Suppressed (https://tmvoid.github.io/lakshit-site/)**
`x-powered-by header absent and server version masked`

[PASS] **Subresource Integrity (SRI) / Local Script Origin Verified (https://tmvoid.github.io/lakshit-site/)**
`Inspected 1 script tag(s); 0 unverified external scripts found`

[PASS] **Sensitive Route Protected (/.env) (https://tmvoid.github.io/lakshit-site/.env)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/.git/config) (https://tmvoid.github.io/lakshit-site/.git/config)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/lakshit-site/assets/index-Dj3RxHWY.js.map) (https://tmvoid.github.io/lakshit-site/assets/index-Dj3RxH WY.js.map)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Client JavaScript Bundles Verified Free of Leaked Secrets (https://tmvoid.github.io/lakshit-site/)**
`Inspected 1 bundle(s) (745795 bytes); 0 leaked keys found`

[PASS] **HTTP Verb & TRACE Restriction Verified (https://tmvoid.github.io/lakshit-site/)**
`OPTIONS check completed; TRACE disabled`

[PASS] **GraphQL Unauthenticated Introspection Protected (https://tmvoid.github.io/lakshit-site/)**
`Probed /graphql and /api/graphql - no unauthenticated schema dump exposed`

[PASS] **URL Redirect Query Parameters Validated Against Open Redirects (https://tmvoid.github.io/lakshit-site/)**
`Tested ?redirect=, ?next=, ?url=, ?returnTo= - no external 3xx Location reflection`